

6. Explain common threat vectors and attack surfaces

Introduction

- We will look at the common threat vectors that we face in everyday life and how best to secure corresponding attack surfaces.

Message-Based

- Message-based vectors include a wide array of attack methods, from email phishing to SMS scams and even social media messaging.
- It may be gentle communication platforms as vehicles for malicious payloads.
- Attackers leverage our trust to exploit our defences.
- These vectors include the following:

Email:

- This essential tool in modern communication conceals a trove of cyber threats.
- However, its show as a gentle communication medium is far from the truth.
- Phishing emails present themselves as legitimate correspondence while harbouring malicious intent.
- These emails manipulate users into opening the emails or clicking on malicious links, unintentionally opening the door to data breaches, malware injections, and financial harm.

Short Message Service (SMS):

- While SMS may appear harmless, its role in delivering sensitive information and authentication codes makes it a prime target for attackers.
- **SMS phishing (smishing)** uses text messages to cheat users into revealing personal information or downloading malicious attachments.

Instant messaging (IM):

- IM attack vectors often exhibit a higher level of security compared to traditional SMS, primarily due to the widespread adoption of end-to-end encryption in many popular IM platforms.
- IM vulnerabilities range from the distribution of malware-laden attachments to socially engineered messages that persuade users into clicking malicious links.

Image-Based

- Cyber attackers exploit image-based vulnerabilities to embed harmful code or links.
- These seemingly harmless images can lead to unauthorized access, ransomware attacks, and system compromises.

File-Based

- Malicious files exploit software vulnerabilities, launching cyber-attacks when opened.

- These files execute harmful code, enabling hackers to breach systems, steal data, or gain control remotely.
- We can defend against file-based attacks by implementing vigilant file screening and attachment blocking to pre-emptively intercept threats before they breach our company's network.

Voice Call

- Attackers can manipulate voice calls to cheat users into revealing personal information, gaining unauthorized access, or executing financial fraud.
- An example of this is caller ID spoofing, in which the attacker cleverly disguises the true origins of a call, making it look like someone else is contacting you.

Removable Device

- Removable devices, from USB drives to external hard drives, offer a convenient means of data transfer. However, these devices can serve as channels for malware transmission.
- When introduced into a network or system, infected removable devices can spread malware, compromise security, and enable unauthorized access.
- For example, a malicious USB drive can be dropped in a reception area and when the unsuspecting finder plugs the USB into their computer to trace its owner, they unknowingly trigger a file housing malicious code.
- This code, once activated, grants the attacker control over the victim's computer.
- Any USB files that are found should be given to the security team, who will open it up in a sandbox, preventing any malicious code from executing on the network.

Vulnerable Software

- Vulnerable software refers to computer programs or applications that possess weaknesses or flaws that can be exploited by malicious actors to gain unauthorized access, compromise data, or disrupt system functionality.
- These vulnerabilities often arise from coding errors, design flaws, or outdated components within the software.
- To mitigate the risks associated with vulnerable software, regular security updates, patch management, and adherence to best coding practices are essential.
- When looking at vulnerable software scanning, one crucial aspect is the identification and assessment of vulnerable software.
- This process involves scanning systems to detect potential vulnerabilities that could be exploited by threat actors.
- In this regard, organizations typically have two primary scanning methodologies to choose from:
 - client-based scanning
 - agentless scanning.

Client-based scanning:

- Client-based scanning (in which an agent resides on each host) operates as a tool for automating vulnerability discovery and classification, efficiently reporting to a central management server.

Agentless scanning:

- Agentless-based scanning, which is the preferred method for threat actors during investigation, is employed to scan hosts without necessitating any installations.
- Examples of agentless-based scanning are Nmap and Wireshark.

Unsupported Systems and Applications

- Vulnerabilities of unsupported systems and applications, including legacy and third-party software, are prime targets for malicious actors.
- Hackers are skilful at exploiting known vulnerabilities to which patches or updates have not been applied.
- By targeting these software gaps, attackers can gain unauthorized access, exfiltrate sensitive data, or launch large-scale attacks such as ransomware infections.

Unsecure Networks

- Unsecured networks are vulnerable as they allow unauthorized users to connect.
- Nowadays, we use various network technologies, including wireless, wired, and Bluetooth connections, which can act as potential gateways for threats that expose our data and privacy.
- These are further described below:

Wireless networks:

- A wireless network using open system authentication lacks encryption.
- Any data exchanged between a guest's device and a hotel's network, for instance, is sent in plain text that cybercriminals with the right tools can intercept to eavesdrop on this data, potentially accessing sensitive information such as login credentials, personal messages, and financial details.
- Strategies to protect wireless networks include using encryption and disabling the broadcast of the **service set identifier (SSID)**, which acts as the network's name.
- By disabling this broadcast, network administrators obscure the network's presence, making it less visible to casual attackers.
- Another option is MAC filtering, which secures the network by ensuring that only an approved user's MAC address is added to the wireless access point.

Wired networks:

- Wired networks, which are often used by companies that rely on connectivity, hide risks when left unsecured.
- Without proper encryption and access controls, unauthorized physical access to network ports can lead to data breaches and malware attacks.

- To preserve the integrity and reliability of these networks, implementing stringent access controls, encryption protocols, and consistent security assessments is crucial.
- We should also remove the patch cables for ports that are not being used.

Bluetooth:

- A **personal area network (PAN)** is a Bluetooth network. Bluetooth features, such as easy pairing, can open the door to security breaches.
- Attackers equipped with specialized tools can exploit the relaxed pairing process, potentially infiltrating devices and compromising sensitive data.
- To mitigate these risks, users must adopt a proactive stance by enabling Bluetooth only when actively needed.
- Additionally, users should regularly update their devices with the latest security patches to close any potential vulnerabilities.

Open Service Ports

- Unsecured open service ports are like unlocked doors for cybercriminals. These ports provide entry points to networked systems and applications.
- Attackers scan for these openings and exploit them to gain unauthorized access or execute malicious code.
- Regular port scanning and closing unnecessary ports are vital steps in minimizing this attack surface.

Default Credentials

- Default credentials (often set by manufacturers for ease of installation) are a glaring point of weakness.
- Attackers leverage default usernames and passwords to gain unauthorized access to systems and applications, and these default credentials are posted on several websites.

Supply Chain

- A supply chain is the transformation of raw materials into finished products and making them available to consumers.
- A supply chain comprises
 - suppliers
 - manufacturers
 - distributors
 - retailers
- In procurement management, it proves beneficial to classify various types of connections. The following list compares the different parties in supply chain management:

Managed service providers (MSPs):

- An MSP is a third-party organization that fulfils all of a company's IT needs.

- A single compromise within an MSP's infrastructure can ripple across multiple clients, leading to cascading breaches.
- To mitigate this risk, organizations should demand stringent security standards from their MSPs, including regular audits, robust access controls, and a commitment to promptly patch any vulnerabilities.

Vendors:

- The relationships between organizations and their vendors often involve the sharing of sensitive information. Yet, vendors can unwittingly serve as vectors for cyber threats.
- Organizations should implement comprehensive vendor risk assessments, evaluating security protocols and practices before granting access to their networks or data.
- Regular communication and collaboration ensure alignment in security expectations, minimizing the potential vulnerabilities introduced through vendor connections.

Suppliers:

- Suppliers, referred to as third-party contributors who provide goods or services, are an integral part of the process but can also introduce risks.
- It's important to scrutinize suppliers' security practices as part of a comprehensive supply chain risk management strategy.

Human Vectors/Social Engineering

- In the realm of human vectors and social engineering, attackers exploit the vulnerabilities of human psychology to breach digital defences.
- We could call this "hacking the human" as the attacker tries to catch their victim off guard.
- The hacker manipulates the victim by appealing to desires based on money or security or pretending to be a person or company the victim trusts to gain unauthorized access or information.
- The following list describes the tactics that cybercriminals employ to manipulate and deceive and explores the strategies we can adopt to outwit these psychological manipulations:

Phishing:

- Using seemingly genuine emails, messages, or websites, attackers cast their nets wide, aiming to trap recipients into revealing personal data, passwords, or financial details.
- Attackers capitalize on human curiosity, urgency, and trust, often leading recipients to click on malicious links or provide confidential information unknowingly.
- For example, an attacker might send emails that seem to come from a legitimate authority, such as the tax department, claiming that the recipient has a tax refund.

Spear phishing

- It involves attacks directed at specific groups, such as the board of directors at a company.
- These emails are tailored to create a sense of authenticity and urgency, enticing the victim to click on a link embedded in the email, which typically leads to a malicious website or triggers a malware download.
- Due to the frequent occurrence of these attacks, many companies will conduct phishing campaign simulations to prepare their employees to deal with these events responsibly.
- The company conducts mock phishing campaigns by sending deceptive emails to employees, followed by remedial training for those who fall victim, in a proactive approach to strengthen cybersecurity awareness.

Smishing:

- Smishing extends phishing to text messages, tricking recipients into clicking malicious links.
- A seemingly harmless SMS might prompt you to click a link that downloads malware onto your device.

Misinformation/disinformation:

- **Misinformation** refers to the spread of false or inaccurate information by one or many individuals without the intent to mislead and who may believe that disinformation to be true.
- The intentional spread of false or misleading information is called **disinformation** and can manipulate perceptions and decisions.
- False news articles, especially during times of crisis, can influence public opinion and incite panic.
- For example, say an attacker creates a fake news article claiming that a popular social media platform will shut down due to data breaches. This fabricated news is designed to cause panic and prompt users to share it further, amplifying its reach. The attacker's goal is to disrupt the platform's user base, erode trust in information sources, and create chaos.

Impersonation:

- An attacker may adopt a false identity such as a member of the police force or helpdesk team to gain your trust.

Business email compromise:

- A cunning criminal may compromise a legitimate business email account to orchestrate financial fraud.
- They might carry out an invoice scam where they change payment details on a legitimate invoice, thereby redirecting funds to the attacker's account.

Pretexting:

- Pretexting involves fabricating a scenario to extract information.
- An attacker might pose as a tech support agent, convincing you to share sensitive data under the guise of resolving an issue.

Watering hole attacks:

- Watering hole attacks are like cunning predators waiting at watering holes in the wild.
- Cybercriminals compromise legitimate websites (knowing that users trust these sites) by implanting malicious code. When unsuspecting visitors frequent these websites, their devices are infected with malware, which then grants the attackers access to valuable data.
- The infamous watering hole attack on the U.S. Department of Labor's website in 2013 underscored the potential for compromise even on trusted platforms.

Brand impersonation:

- Brand impersonation involves malicious actors imitating reputable brands (such as banks and financial institutions) to deceive unsuspecting users.
- These cybercriminals exploit on brand recognition, creating websites or emails that appear authentic.
- Unsuspecting victims may share sensitive information or interact with fraudulent sites, falling to identity theft or financial scams.
- Heightened cybersecurity awareness and stringent verification processes are essential to counter this threat and prevent the erosion of trust in reputable brands.

Typosquatting:

- Typosquatting exploits typing errors. Cyber attackers register domains that bear great similarity to legitimate domain names with minor changes such as spelling errors or missing symbols.
- Users accidentally navigate to these deceptive sites, which can lead to malware installation or phishing attempts.
- A famous example of this was the typosquatting attack on Twitter in 2013, which exploited mistyped URLs to distribute malware and gather sensitive information. Users were redirected to a spoofed Twitter website page from which their login credentials were stolen.
- Enhanced vigilance, browser extensions that warn of potential typosquatting, and domain monitoring are crucial to minimize this threat's impact, preserving user security.